



ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

SEGURIDAD Y PRIVACIDAD DE TI

GESTIÓN DE RIESGOS KERALTY

ENFOCADO EN

Análisis Caso Estudio

**ANDERSSON DAVID SÁNCHEZ MÉNDEZ
CRISTIAN SANTIAGO PEDRAZA RODRÍGUEZ
LAURA VALENTINA GUTIÉRREZ RICO**

PROFESOR:

JAVIER IVAN TOQUICA BARRERA

Lugar: Bogotá

Fecha: Febrero 06/2026



GESTIÓN DE RIESGOS KERALTY

Estudiante: Andersson David Sánchez Méndez

Estudiante: Cristian Santiago Pedraza Rodríguez

Estudiante: Laura Valentina Gutiérrez Rico

Enfocado en: Análisis Caso Estudio

Fecha: Febrero 06, 2026

1. Utilizando el ataque de Grupo Keralty, responda a las siguientes preguntas:

a) ¿Cuál fue el activo afectado?

Infraestructura tecnológica que soporta los sistemas de información críticos del negocio, específicamente:

- Sistemas de información para agendamiento de citas, atención digital y autorizaciones.
- Bases de datos corporativas que almacenan información administrativa, operativa y potencialmente datos personales de afiliados.
- Plataformas digitales que garantizan la continuidad del servicio de salud.

Desde la perspectiva de ISO 27005, se afectaron tanto:

- Activos primarios: información y procesos de atención en salud.
- Activos de soporte: servidores, aplicaciones y red corporativa.

b) ¿Cuál fue la amenaza presente?

Ataque cibernético intencional tipo ransomware, ejecutado por un actor externo malicioso (grupo RansomHouse), cuyo objetivo fue:

- Obtener acceso no autorizado a sistemas internos.
- Sustraer información sensible.
- Interrumpir la operación normal.
- Extorsionar a la organización mediante la amenaza de publicación de datos.

c) ¿Cuál fue el riesgo materializado?

Interrupción prolongada de servicios digitales críticos y la exposición de información interna, lo cual derivó en:

- Afectación directa a la prestación del servicio de salud.
- Riesgo legal y regulatorio por posible exposición de datos personales.
- Daño reputacional significativo.
- Impacto operativo y financiero.

d) ¿Se tenía alguna vulnerabilidad que permitió el ataque?

Sí, tenían ciertas vulnerabilidades, aunque la organización contaba con buena infraestructura tecnológica, el ataque evidenció vulnerabilidades técnicas y organizacionales las cuales facilitaron que el atacante accediera a sistemas críticos y comprometiera información sensible, algunas de estas fueron:

- Falta de segmentación adecuada de la red, lo que permitió el movimiento lateral del atacante.
- Sistemas desactualizados y también expuestos.
- Falta de herramientas para la detección temprana frente a accesos no autorizados.
- Falencias en la protección de las credenciales privilegiadas.

e) ¿Cuál fue el vector de ataque?

El vector de ataque más probable fue el acceso inicial remoto no autorizado el cual permitió al actor malicioso ingresar a la red corporativa sin ser detectado inicialmente mediante, algunas credenciales que estaban comprometidas, servicios expuestos a Internet como VPN y otros accesos remoto y ataques de phishing dirigidos a usuarios internos.

f) ¿Cuál fue el exploit utilizado?

No se hizo público un exploit específico, pero de acuerdo con el comportamiento del grupo cibercriminal RansomHouse, se cree que se hizo uso de una vulnerabilidad “zero-day”, una explotación de vulnerabilidades conocidas en servicios expuestos o sistemas sin parches y técnicas de exfiltración de datos antes del cifrado.

2. Teniendo en cuenta los elementos identificados en el punto anterior, determine el nivel de riesgo al que la empresa se veía expuesto siguiente la siguiente tabla de clasificación del riesgo. Liste 2 riesgos.

Table 1: Risk Scoring Legend

Likelihood: Probability of occurrence of the risk event due to gaps identified.

Impact of the risk events in the form of regulatory, operational, legal, financial or reputational consequences.

Risk Rating Matrix		Impact		
		Low	Medium	High
Likelihood	Low	L	M	M
	Medium	M	M	H
	High	M	H	C

Risk Summary			
Riesgo	Likelihood	Impact	Overall Risk
Exposición de los datos personales	Media	Alto	Alto
Interrupción en los servicios de salud	Alto	Alto	Critico

a) Justificación de Probabilidad:

- Riesgo 1: Es media ya que el atacante logró el acceso prolongado a los sistemas y utilizó técnicas de exfiltración de información antes de ejecutar la extorsión.
- Riesgo 2: Es un riesgo alto debido a la dependencia de los sistemas digitales para toda la atención médica.

b) Justificación Impacto:

- Riesgo 1: El impacto es alto debido a posibles sanciones regulatorias, demandas legales, pérdida de confianza de los usuarios y daño personal.
- Riesgo 2: El impacto es alto porque afectó directamente la prestación del servicio de salud el cual es un derecho fundamental, generando intervención de entes de control y afectación a millones de usuarios.

3. Teniendo en cuenta los puntos anteriores, proponga un control apropiado para mitigar el riesgo, y realice nuevamente la evaluación del riesgo utilizando las tablas descritas en el punto anterior.

Table 1: Risk Scoring Legend

Likelihood: Probability of occurrence of the risk event due to gaps identified.

Impact of the risk events in the form of regulatory, operational, legal, financial or reputational consequences.

Risk Rating Matrix		Impact		
		Low	Medium	High
Likelihood	Low	L	M	M
	Medium	M	M	H
	High	M	H	C

Risk Summary			
Control	Likelihood	Impact	Overall Risk
Segmentación de red y mínimo privilegio	Media	Media	Media
Autenticación multifactor (mfa)	Baja	Media	Media

a) Justificación de Probabilidad:

- Riesgo 1: La probabilidad de una exfiltración masiva de datos disminuye al restringir esos accesos innecesarios a bases de datos sensibles.
- Riesgo 2: La probabilidad baja, ya que el robo de credenciales por sí solo no es suficiente para acceder a todos los sistemas.

b) Justificación Impacto:

- Riesgo 1: El impacto se reduce al evitar el acceso directo a información clínica y personal.
- Riesgo 2: El impacto baja debido a la reducción de accesos indebidos a información que es crítica.

REFERENCIAS

- Infobae. (2023). *Ciberataque a Sanitas: hackers revelaron más información clasificada de la EPS*. Retrieved from <https://www.infobae.com/colombia/2023/03/14/ciberataque-a-sanitas-hackers-revelaron-mas-informacion-clasificada-de-la-eps/> (Reference for Parts 1, 2 and 3: Incident timeline, impact, CIA triad and data exposure).
- Defensoría del Pueblo. (2022). *Defensoría requirió a Keralty (EPS Sanitas y Colsanitas) para que restaure sus servicios digitales y garantice el derecho fundamental a la salud*. Retrieved from <https://www.defensoria.gov.co> (Reference for Parts 1 and 3: Institutional response, users' rights, privacy and health impact).
- Fortinet. (2023). *Threat Actor Profile: RansomHouse Ransomware*. FortiGuard Labs. Retrieved from <https://fortiguard.fortinet.com/threat-actor/6250/ransomhouse-ransomware> (Reference for Part 5: Threat actor overview, ransomware and double extortion model).
- Acronis. (2023). *RansomHouse breaches multiple organizations and publishes terabytes of stolen data*. Acronis Cyber Protection Blog. Retrieved from <https://www.acronis.com/en-eu/tru/posts/> (Reference for Part 5: International attacks and data-leak strategy).
- CSIDB – Cyber Security Incident Database. (n.d.). *RansomHouse threat actor profile*. Retrieved from <https://www.csidb.net/csldb/actors/> (Reference for Part 5: Historical attacks, sectors affected and operational behavior).
- DPL News. (2022). *Colombia: Sanitas restablece su oficina virtual tras ciberataque*. Retrieved from <https://dplnews.com> (Reference for Part 1: Service disruption, recovery process and continuity actions).
- National Institute of Standards and Technology (NIST). (2018). *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*. Retrieved from <https://www.nist.gov/cyberframework> (Reference for Parts 1 and 4: Incident response lifecycle and cybersecurity scope).
- ISO/IEC. (2012). *ISO/IEC 27032: Guidelines for Cybersecurity*. International Organization for Standardization. (Reference for Part 4: Difference between Information Security and Cybersecurity)